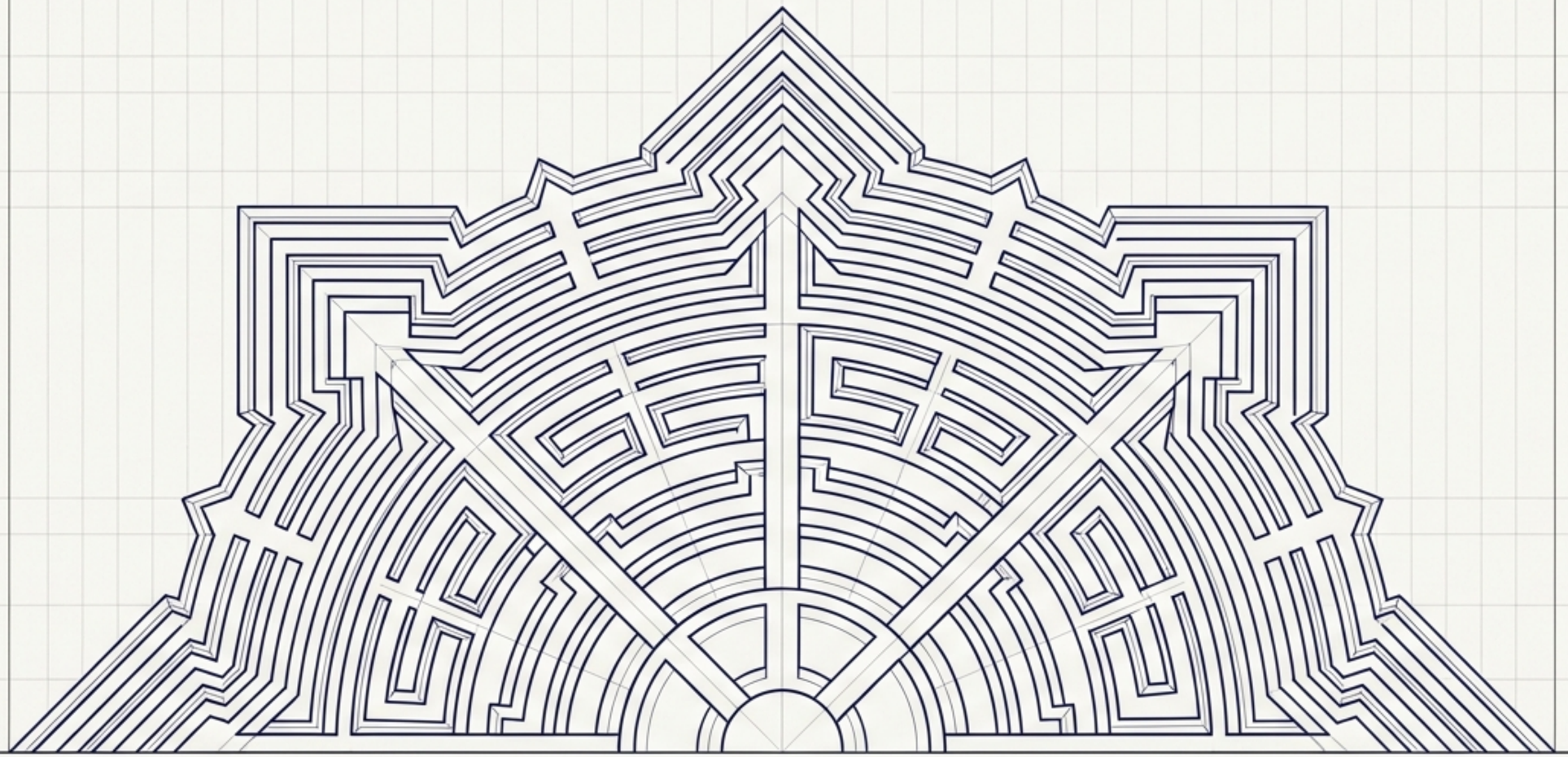
[AUDITORÍA DE SISTEMAS ASISTIDOS POR IA]

Arquitectura vs. Inteligencia Artificial

El Blueprint de la Paranoia: Ciberseguridad, FinOps y Criterio de Recursos.



NotebookLM



El Atajo de la IA

Conveniencia Matemática

El camino algorítmico más rápido de un LLM para entregar resultados visuales suele ser desactivar o ignorar las capas de seguridad para evitar errores de CORS o autenticación.



El Paradigma del Arquitecto

Paranoia Absoluta

Asume siempre que la máquina dejó las puertas traseras abiertas por conveniencia.

Un Arquitecto audita el código generado por IA con la mentalidad de un atacante. La IA no es tu colega; es un motor de velocidad.

NotebookLM

Capa 1 (Datos): El Ataque DevTools y la Fuga de Datos



El Entorno

Atacante abre el navegador en Modo Incógnito.



La Infiltración

Presiona F12 (DevTools) y accede a la consola de JavaScript.

La Ejecución

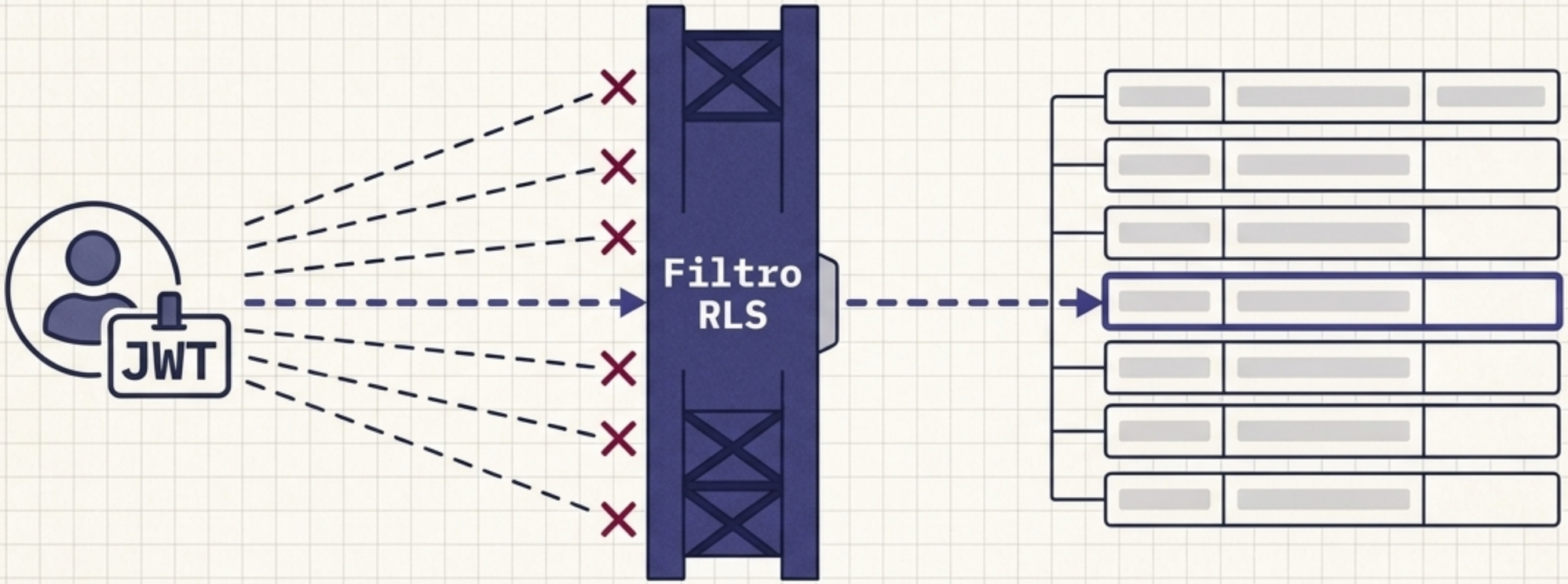
```
> await supabase.from(
'users').select('*')
```

Sin hackear contraseñas, la base de datos completa ha sido extraída porque la IA omitió asegurar la tabla.



NotebookLM

El Escudo de Datos: Row Level Security (RLS)



MANDATO DEL ARQUITECTO

Obliga a la IA a proveer siempre los scripts SQL para activar las políticas de RLS. Esto garantiza que cualquier consulta desde el frontend quede criptográficamente limitada por el JWT del usuario.

NotebookLM

Capa 2 (Credenciales): El "God Mode" Expuesto

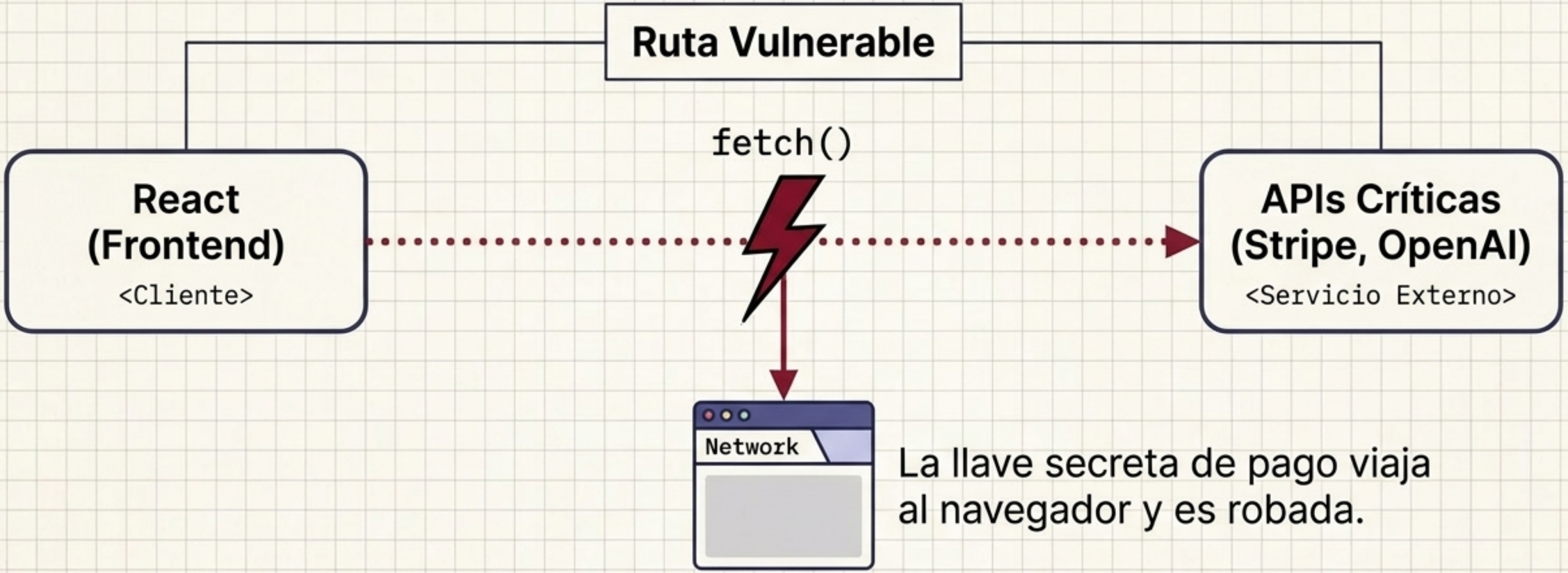
	anon_key	service_role_key
Entorno Permitido	Frontend / React	Backend .env Exclusivo
Nivel de Acceso	Limitado por RLS	Modo Dios: ignora toda la seguridad
Riesgo de Fuga	Bajo (Diseñada para ser pública)	Crítico: Cualquier visitante puede extraerla y borrar la base de datos.



ALERTA: La IA frecuentemente sugerirá usar la llave 'Modo Dios' en el Frontend para sortear problemas temporales de permisos. Si haces esto, tu infraestructura está comprometida.

NotebookLM

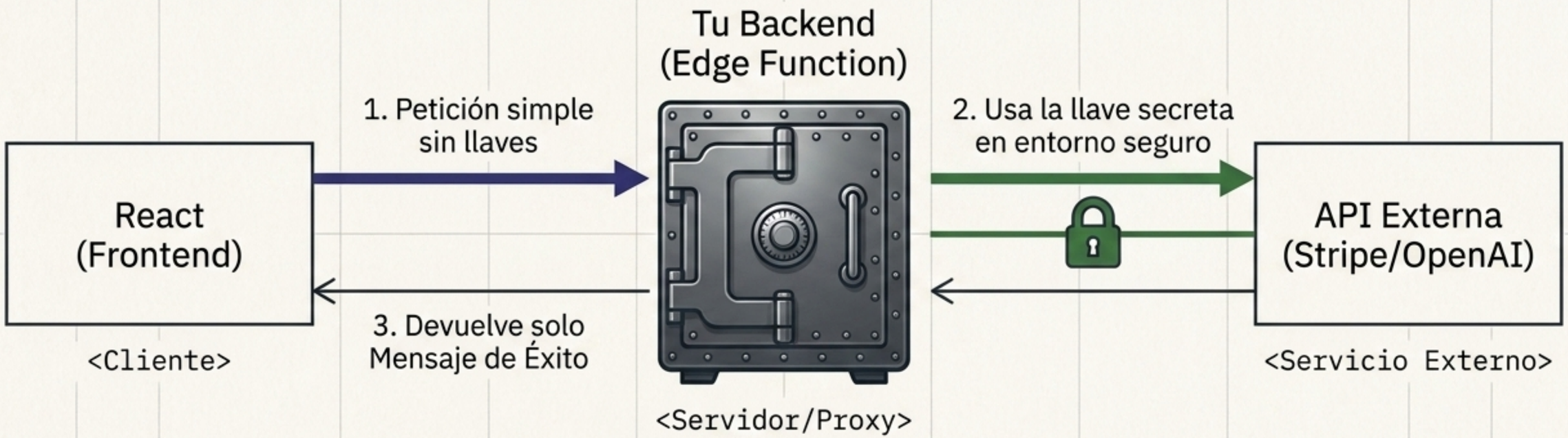
Capa 3 (Operaciones): El Peligro del Fetch Directo



Contexto: Cuando tu aplicación procesa pagos o consume APIs de costo, el Frontend jamás debe hacer la petición directamente.

NotebookLM

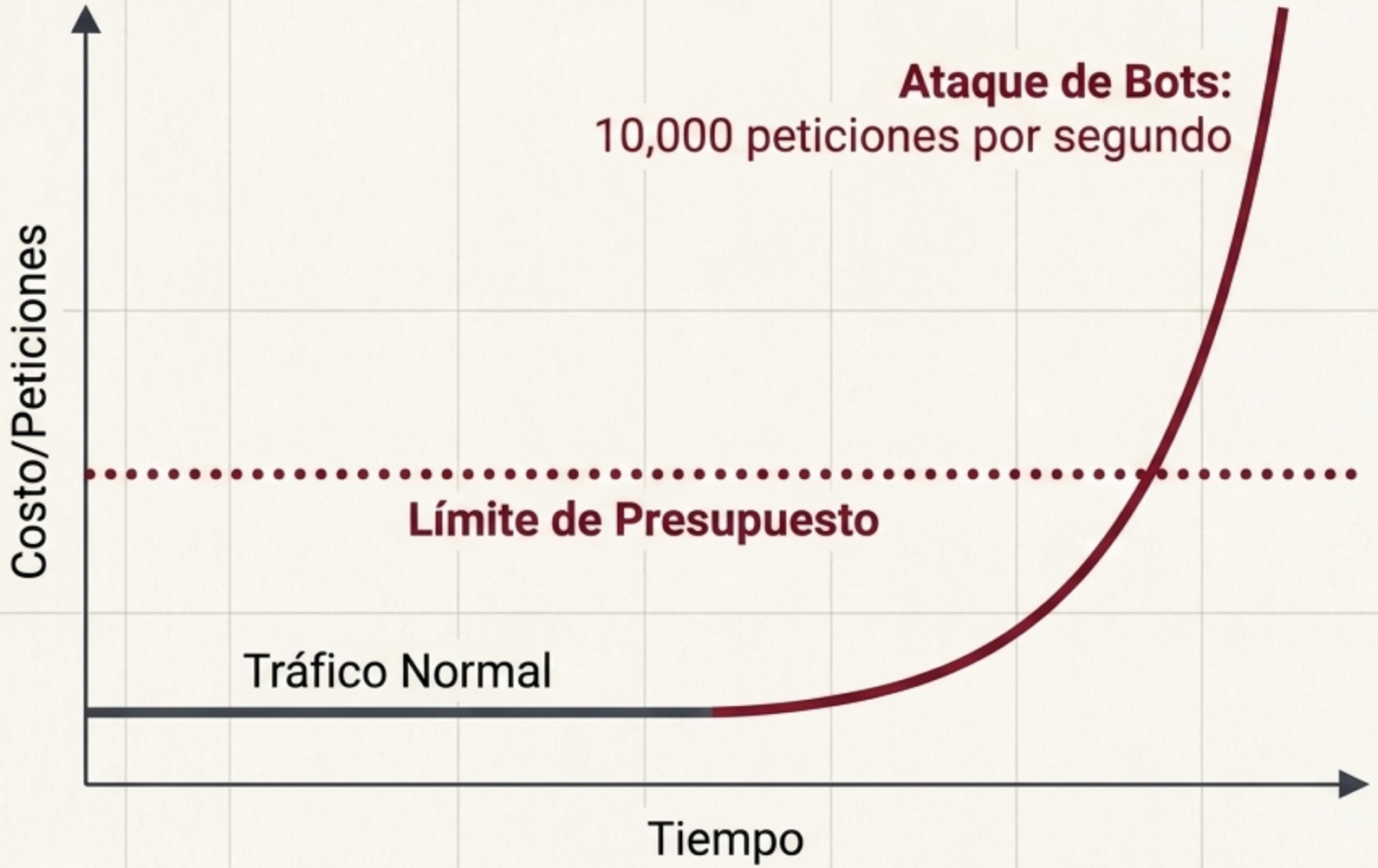
El Escudo Operativo: Arquitectura Server-to-Server (S2S)



El puente (Proxy) asegura que las credenciales críticas nunca toquen el navegador del cliente.

NotebookLM

Capa 4 (Infraestructura): FinOps y el Ataque a la Billetera



El Escenario: Tu arquitectura S2S es perfecta. Tu llave de pago está segura. Pero un bot ataca tu Edge Function.

El Impacto: La función ejecuta 10,000 llamadas a la API de OpenAI usando tu infraestructura legal. No te roban datos, pero quiebran financieramente a la empresa con una factura masiva.

NotebookLM

El Escudo de Infraestructura: Rate Limiting

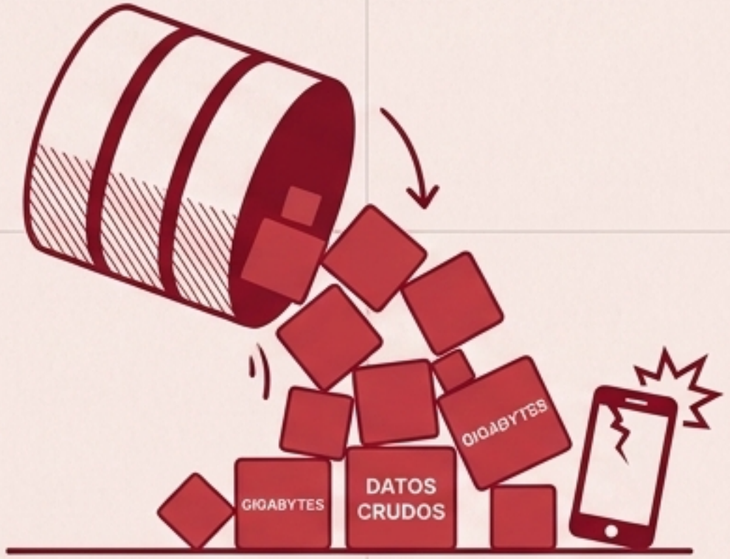
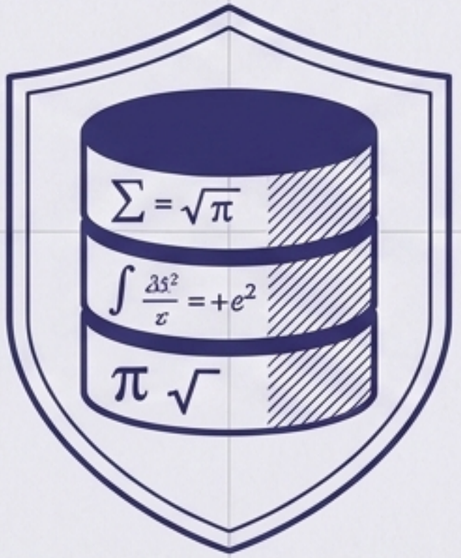


Concepto: Cortar el ataque en la capa de red antes de que accione el servicio de costo.

Instrucción para la IA: En esta Edge Function, antes de llamar al servicio externo de costo, implementa un mecanismo de Rate Limiting para rechazar operaciones si una misma IP hace más de 5 peticiones por minuto.

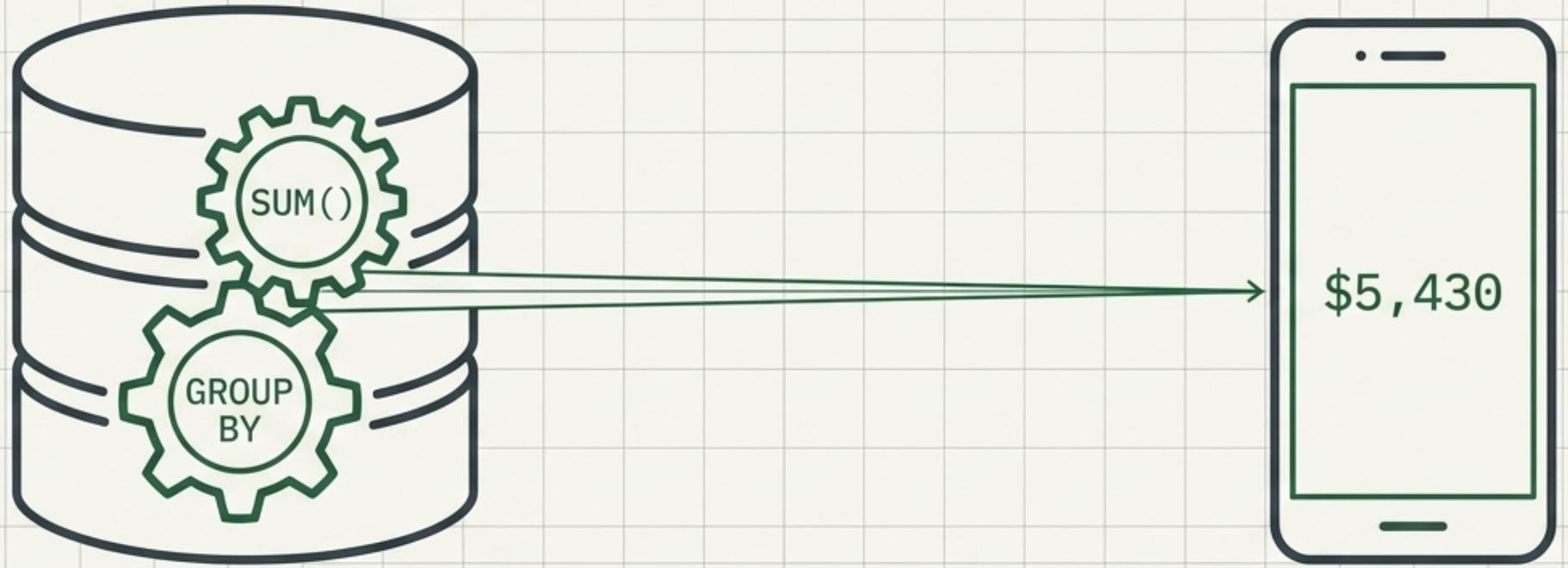
NotebookLM

Capa 5 (Eficiencia): Criterio de Recursos y Desperdicio

El Frontend Gordo (Desperdicio)	El Servidor Musculoso (Optimización)
	
La IA tiende a pedir grandes volúmenes de datos para filtrarlos mediante ciclos “for” o “reduce” en React. Revienta la RAM del celular y genera costos masivos de lectura.	Las bases de datos están hiper-optimizadas para las matemáticas. El cálculo debe ocurrir en el origen.

NotebookLM

El Escudo de Eficiencia: Funciones Nativas y RPC



MANDATO DEL ARQUITECTO: Exige a la IA que use funciones nativas de SQL o RPCs (Remote Procedure Calls) en Supabase para que el cálculo se procese en el servidor. Devuelve al cliente únicamente el resultado final.

NotebookLM

La Matriz de Auditoría del Arquitecto

Capa	El Atajo de la IA	El Mandato del Arquitecto
Datos	Deja tablas abiertas para iterar rápido.	Exige scripts SQL con políticas RLS.
Credenciales	Inserta `service_role_key` en React para evitar errores.	Usa `anon_key` en UI; llaves maestras solo en `.env`.
Operaciones	Llama a APIs externas directamente vía `fetch()`.	Implementa puente `S2S` (Edge Functions).
Infraestructura	Expone funciones de alto costo sin límites.	Protege la facturación con Rate Limiting.
Eficiencia	Usa `reduce` en UI descargando la BD completa.	Delega el cálculo al servidor con SQL Nativo / RPC.

NotebookLM